

ZRP Social: Full Product Surgical Certification

Repository `LeonidasSpart/zrp-social-platform` · 25 September 2026 · Delivered via PR #400, merged to `main` at `4fe885a`

Final certification: PRODUCTION READY (web).

Android and iOS changes compile in CI but have not been tested on real devices. Five items need a product decision (section 9).

1. Summary

Item	Result
Branch / commits	<code>claude/zrp-full-product-audit-k1e12v</code> : <code>77169e9</code> (API, realtime, money), <code>a8ed6b8</code> (web UI), <code>e5dfc32</code> (native), <code>8930783</code> (CHANGELOG)
Pull request	#400, all CI checks green, merged with a merge commit
Final <code>origin/main</code>	<code>4fe885a6d5f6698c32b8cb09f74145bdde0469ac</code> ; post-merge CI green (iOS build was still running at the time of writing; it passed on the identical PR tree)
API route files audited / changed	282 / 95
Page routes audited	131, each as logged-out, normal user and admin, at 1280px and 375px (786 page loads)
Security issues found / fixed	~60 / ~60
Broken buttons and flows found / fixed	~30 / ~30
Dead or orphaned API routes	12 identified and reported; none deleted (callers may live outside the repo). The public <code>/test debug</code> page was removed.
Tests	2398 / 2398 pass against real Postgres 16 + Redis (+151 over <code>main</code>); no test removed or weakened. Typecheck clean; lint 0 errors; production build passes.
Files changed	224 files, +5665 / -686 lines

2. Method

Eight parallel auditors each took one area (admin/moderation, money and ads, content, messaging and realtime, identity and social graph, frontend-to-route wiring, shared UI and accessibility, native apps), followed by an independent adversarial review of the combined diff. Every finding was traced UI → client call → route → Prisma → response before being fixed.

Race-condition fixes were confirmed by writing the test first and watching it fail on the old code.

Verification used the real stack, not mocks: the integration suites ran against Postgres 16 and Redis 7 exactly as CI does; a production build was crawled with headless Chromium; end-to-end user journeys were driven through the real login form and real API.

3. Status by area

Area	Status	Notes
Payments / withdrawals	FIXED	Withdrawals were impossible for everyone (no wallet-verification UI existed). Signature replay across plan/tip/purchase/ad/HELP closed. Payments from another account's verified wallet refused.
Ads / monetisation	FIXED	Stored XSS via ad target URL; budget raise after payment; staff notes leaked to advertisers; status races.
Messaging / realtime	FIXED	Server crash from a malformed socket payload; internal call-push route publicly reachable; push-endpoint SSRF; stuck unread badge; fake delete relays.
Feed / posts / comments	FIXED	Paid/private content leaked via ~10 routes; poll vote race; stored javascript: links; interaction routes ignored visibility.
Profiles / identity	FIXED	OAuth account takeover of unverified accounts; moderator could ban/demote admins; profile ILIKE wildcard; blocks ignored in lists/suggestions.
Ambassadors	FIXED	Referral links (?ref=) were never recorded on signup.
Communities / lists	OK	Double-join 500 and blocked-user list adds fixed; role model verified.
Search / discover	OK	Blocked, muted, banned exclusion and premium gating verified.
Notifications	FIXED	Every type now links to a page that exists (web, email, push). Tip/purchase notifications respect blocks.
Localization	OK	29 languages; new keys added with parity; RTL fixes in menus and modals.
Web	VERIFIED	Full crawl + journeys (section 5).
PWA	FIXED	Manifest link pointed at a non-existent route; now serves /manifest.webmanifest . Install flow not tested on a device.
Mobile browser	VERIFIED	375px emulation, touch enabled; no overflow, journeys pass.
iPad / tablet	NOT DEVICE-TESTED	Not emulated separately; no known issues.
Android	COMPILES, NOT DEVICE-TESTED	305 API calls verified against routes; strings localized; "Requested" state fixed. Debug + release builds green in CI.

iOS	COMPILES, NOT DEVICE- TESTED	260 API calls verified; comment-edit decode crash fixed; group deep links. Xcode build green in CI.
X-reference UX	APPLIED	Menus close on Escape/outside click, focus returns; private-account repost/quote rules match X.
Responsive	VERIFIED	No horizontal overflow at 1280 and 375 on any page.
Accessibility	FIXED	9 modals with dialog semantics; ~30 icon-only buttons labelled; 40px touch targets on post menus.
Performance	OK	Manifest miss no longer triggers a DB lookup per page load; AI chat context window corrected; no regressions found.
Security	FIXED	See section 4.

4. Security fixes

Access control and data exposure

- Paid (pay-per-view) and private-account content leaked through the feed, Shorts, bookmarks, all four profile tabs, `og:image`, the premium-post GET, article bodies and quote embeds.
- Staff-only support notes were returned to the ticket owner (and labelled "Internal note" in their UI).
- Ad `adminNote` returned to advertisers.
- A moderator could ban an admin, demote an admin via the journalist routes, or self-ban; ban was a blind toggle.
- API keys kept working after a plan downgrade or subscription expiry.
- Followers of a private account that had blocked them could still list its connections.

Account takeover and identity

- Google/Apple sign-in linked to any row with the same email, including an unverified one registered by an attacker with their own password. The unverified row's password and tokens are now cleared on OAuth link.
- Deleted or renamed accounts could keep a valid cached session for up to 30 seconds.

Money

- One transaction signature could be credited as a plan payment and again as a tip (or by two different users).
- Anyone could claim a payment sent from another account's verified wallet (tip, premium purchase, ad payment, HELP contribution).
- Ad budget could be raised after paying; campaign activation could undo a staff cancel; failed verification overwrote CANCELLED.
- Deleting a HELP campaign could erase withdrawals in flight; HELP withdrawal reject was not transactional.
- Cron and internal-push secrets compared with `!==`; now SHA-256 + `timingSafeEqual`.

Injection and SSRF

- Stored `javascript:` URLs accepted in profile website, journalist portfolio, article source, opportunity apply/resume links, ad target URL, news source, charity proof and RSS-imported links. Rejected on write; rendered inert for existing rows.
- SSRF guard bypass via bracketed IPv6 literals and non-dotted mapped addresses (`[::1]` , `[::ffff:7f00:1]`).
- Push subscriptions accepted any URL; the server then POSTed to it. Restricted to real push services.
- Profile lookup used raw `ILIKE`, so `/api/users/a%` matched arbitrary users.

Availability and abuse

- Any authenticated socket could crash the whole Node process with a null payload on seven events.
- `/api/internal/call-push` was publicly routable; now loopback-only at the socket level (`internal-route-gate.js`).
- Unauthenticated, unlimited GIF proxy and music play-count endpoints; `mark-read` socket event unvalidated and unlimited.

Races

- `PLAY`: first-clear XP, daily bonus, duel double-submit, duel settlement, XP lost updates, duplicate achievements, AI-generate quota.
- Poll votes lost under concurrency; appeal resolution applied twice; ad review overwrote fresh state; a dozen like/bookmark/repost toggles returned 500 on double-tap.

5. Broken flows and UI fixed

- **Withdrawals:** the server pays only an ownership-verified wallet, and nothing on any platform drove `/api/wallet/link-*`. New `WalletVerifyPanel` (injected Phantom/Solflare/Backpack provider signs a server challenge; never a transaction) in Settings, the creator withdraw modal and HELP withdrawals. The creator modal also sent a typed address the server silently ignored.
- `/support/tickets/[id]` and `/admin/support/[id]` crashed into the error boundary on a missing or forbidden ticket; ticket list crashed on an error body; admin replies failed silently.
- PWA manifest linked to `/manifest`, which resolved to the profile page for a user called "manifest" (a DB lookup per page load, and a login redirect for visitors).
- Notification page fell back to the actor's profile for ~10 types; HELP emails and renewal pushes linked to non-existent pages.
- "Requested" state on a private profile was lost after reload (route never returned `followRequestStatus`); fixed on web and Android.
- Ambassador invite links never attributed signups.
- AI chat sent the model the *oldest* 20 turns of a conversation; provider error text and server config hints were echoed to clients.
- iOS: every saved comment edit showed an error (decode failure on the bare response row); group-conversation deep links opened only the inbox.

- Post "... " menu and repost dropdown: no Escape, no outside-click dismissal, wrong side in RTL, 24px touch target, hard-coded English.
- Nine modals had no dialog role, no Escape, no focus management; close buttons overlapped titles in RTL.
- Comment submit/edit/delete failures were console-only, so buttons appeared dead. Like state now reconciles with the server.
- Admin pages treated 202 "needs manual review" as silent success; payments page rejected `isAdmin` staff.

6. Verification

Automated

Check	Result
<code>npx tsc --noEmit</code>	clean
<code>npx next lint</code>	0 errors, 199 warnings (same count as <code>main</code> : pre-existing <code>no-img-element</code> / <code>exhaustive-deps</code>)
<code>npx vitest run with Postgres 16 + Redis 7</code>	239 files, 2398 / 2398 tests passed, 0 skipped (baseline on <code>main</code> : 2247)
<code>npx next build</code>	passes
CI on PR #400	Typecheck and lint, Tests (Postgres + Redis), Static checks, iOS parity audit, Xcode 26 iOS build, Android debug APK, Android release AAB: all green

Browser crawl (production build, headless Chromium)

All 131 page routes loaded as anonymous, normal user and admin at 1280px and 375px (786 loads), checking uncaught page errors, failed same-origin API calls, error-boundary text and horizontal overflow.

- Before fixes: two pages crashed into the error boundary (`/support/tickets/[id]` , `/admin/support/[id]`).
- After fixes: zero unexplained issues. Remaining 404s are the placeholder id used for detail pages; one transient chunk-load error on `/opportunity/my-listings` did not reproduce (the chunk serves 200).

End-to-end journeys (desktop and 375px)

Real form login → create post with hashtag and mention → post detail → comment → like toggle → hashtag page → send DM with link → conversation → follow request to a private account → "Requested" survives reload → Settings wallet panel and no-wallet guidance → missing ticket not-found state → overflow checks on six pages. 43 of 44 checks passed; the one failure was a test-selector ambiguity (the DM matched three elements), and a screenshot confirmed correct rendering at 375px.

Live server checks

- Loopback call-push with secret: 200. Proxied (X-Forwarded-For): 404. No secret: 401.

- `/manifest.webmanifest: 200, application/manifest+json`.

7. Real device testing

None.

Only headless Chromium at desktop and 375px (mobile emulation with touch) was used. iPad, tablet, PWA install, and physical Android and iOS devices are unverified beyond "compiles in CI". Kotlin and Swift could not be compiled locally (no SDKs in the container); CI builds are the compile proof.

8. Native releases (AAB)

Platform	Current version	New release needed?
Android native	versionCode 32, versionName 4.0.26	Yes to ship this audit's Android changes (versionCode 33 or higher). Nothing was bumped, built or signed in this session.
iOS native	1.0.0 (build 1)	Ships with the next iOS build.
Capacitor wrapper	Android 1 (1.0), iOS 1.0 (1)	No change.

9. Remaining blockers and product decisions

These were left unchanged because each one changes product behaviour rather than fixing a defect.

1. **Report "Ban user" action** records `actionType` but bans nobody; carrying it out interacts with appeals (a banned user has no session and cannot appeal).
2. **No way to reject a payment request:** a fake crypto payment claim stays pending forever.
3. **Password change/reset does not sign out other sessions:** JWT sessions are self-contained; fixing this needs an additive schema column plus a check in `getUserAuthState`.
4. **Payments from unlinked wallets** can still be front-run by whoever submits the signature first; closing it means requiring a linked wallet for every payment.
5. **Debug keystore SHA-1** is registered on the production Google OAuth Android client; remove it in Google Cloud / Firebase (outside the repo).

Behaviour changes users may notice

- Approved followers of a private account can no longer repost or quote its posts (X-style protected posts).
- An unverified password account that later signs in with Google/Apple loses that password and must use "forgot password".
- `/api/internal/*` answers only loopback connections.

10. Orphaned API routes (reported, not deleted)

POST /api/user/avatar (superseded by update-avatar), GET /api/auth/verify-email (old email links), GET /api/profile/[username]/posts (superseded), POST /api/upload (raw upload, UploadThing preferred), GET /api/hashtags/search, GET /api/discover/people (no UI yet), GET /api/ads/campaigns/[id]/stats, GET /api/health (external probe), GET /api/cron/publish-scheduled-posts and play-daily-rotation (Railway-triggered), GET /api/external/me and /me/posts (third-party API), /api/creator/premium-post and premium-purchase (no create/buy UI on any platform). /api/wallet/link-challenge and link-verify were orphaned before this PR and are now consumed by WalletVerifyPanel.

Generated from the audit session on 25 September 2026. Full per-fix detail is in the commit messages of 77169e9, a8ed6b8 and e5dfc32, and in the CHANGELOG entry for #400.